# DATA ITEM DESCRIPTION

**Title:** Security Evaluation Document (SED)

**Number:** DI-MISC-81762B
**AMSC Number:** 10424
**DTIC Applicable:** No
**Office of Primary Responsibility:** NS/C214
**Applicable Forms:** N/A

**Approval Date:** 20230821
**Limitation:** N/A
**GIDEP Applicable:** No
**Project Number:** MISC-2023-007

**Use/Relationship:** The Security Evaluation Document (SED) provides information about the architectural design of a High Assurance Device (HAD) and its detailed implementation throughout the development. The SED must provide sufficient details to determine the adequacy of the design and ensure appropriate system security requirements are met. Additionally, the SED must contain fail-safe analysis of unauthorized events, Covert Channel Analysis (CCA), and anti-tamper design details. The SED supports security evaluations by documenting HAD design details previously collected from the CCA report, Theory of Design and Operation (TDO), Theory of Compliance (TOC), and Fail-Safe Design and Analysis (FSDA) security evaluation documentation.

This Data Item Description (DID) is applicable to all HAD developments and addresses the system security requirements supplied with the contract in the Security Evaluation Requirements Document (SERD), which supersedes the Information Assurance Security Requirements Document (IASRD).

This DID contains the format and content preparation instructions for the data product generated by the specific and discrete task requirements for this data included in the contract.

This DID supersedes DI-MISC-81762A

**Requirements:**

1. Reference Documents:

- Security Evaluation Requirements Document (SERD), Rev 1.0, dtd Aug 2023
- C Technical Report 02-00, Fail-Safe Design & Analysis: Revised, dtd 27 Jan 2000

2. Format. The SED must be in the contractor's format using MS Word or PDF file formats.

2.1. Paragraph identification. Each paragraph must have a unique contractor specified paragraph identifier.

2.2. Abbreviations and acronyms. Abbreviations and acronyms must be defined when first used in the text and must be placed in the acronym table.

3. Content. The SED must contain:

Source: https://assist.dla.mil -- Downloaded: 2026-10-26T10:53Z
Check the source to verify that this is the current version before use.

3.1. Cover and title page. The following information must be included on the cover and title page:

a. Document Title

b. Date of Issue

c. Version/revision number or letter

d. Contract number

e. Contractor name and address

f. Program title, including HAD name, and nomenclature

g. Security classification according to DOD standards, to include portion markings, if classified.

h. Distribution statement

3.2. Revision control page. This page must facilitate tracking of changes between revisions for timeliness and ease of review. It must include high-level descriptions of changes affected by each revision. The revision control page must list the following information:

a. Each revision number or letter

b. Date of each revision

c. Pages affected by each revision

3.3. Table of contents. The table of contents must identify the following:

a. The title of each major section and paragraph of the SED.

b. The page number, and title of each drawing, illustration, figure and table.

3.4. Chapters. The SED must contain the following chapters of information. It is important to note that the chapters would not be necessarily filled out in sequential order, but filled in as information is available and required.

3.4.1. General Information.

3.4.1.1. The SED provides a view of the architectural design of a HAD and analysis of fail-safe design mechanisms. At a high level it describes the functional and physical design of the HAD, interrelationships between system components, modules, and processors, and security requirements to be met by the HAD. On a detailed level, it provides specific design and implementation information for system security critical functions implemented to satisfy



Source: https://assist.dla.mil -- Downloaded: 2026-10-26T10:53Z
Check the source to verify that this is the current version before use.

individual security requirements. Diagrams and charts are included in the SED for clarity and to support the written description.

3.4.2. Chapter 1. System Requirements and Operational Environment

3.4.2.1.-This chapter provides a concise description of the top-level security services and program requirements of the HAD design to include the Customer, purpose, environment, component-level procurement strategy, production quantity, and interoperability capabilities. This information includes an overview of the system CONOPS to identify all critical information (e.g., data-at-rest, data-in-transit) and technology, if applicable, of the system to be protected, as well as a description of the operational environment and constraints (e.g., airborne, command post, access by cleared personnel only), to support the statement of top-level system security requirements and goals. The level of classification for the data protected by the system must be identified in this chapter also. This chapter will also identify all releaseability requirements that were agreed upon prior to the Systems Requirements Review.

3.4.3. Chapter 2. Security Architecture

3.4.3.1. This chapter provides a detailed description of the system security architecture, components, and functions. This chapter of the SED provides system design details for the security features used to support the security requirement compliance statements provided in Appendix A. In particular, design details should be provided for all system security functions required by the SERD (e.g., access control, authentication, alarms and alarm checks, bypass policies, health checks, known answer test (KAT), power transient detection, cryptographic implementations, key management, randomizer design, auditing, and zeroization). The security architecture should also discuss redundant processors and comparators implemented to monitor system functions to ensure a robust High Assurance, security design. A functional diagram and description of the Security Isolation Boundary, formerly the INFOSEC Boundary, identifying the critical hardware and software components used to comply with the security requirements must be included in this section. The system security features should provide a functional flow of all system operations to demonstrate how the product encrypts, decrypts, routes, stores and transmits classified data to meet customer mission needs described in Chapter 1. The requirement compliance statements in Appendix A should reference the appropriate sections of Chapter 2 to provide the security design details needed to explain compliance. The following lists the type of supportive information and level of detail that should be included in this chapter. Note that this is not an exhaustive list, but should be used as an example.

a. Commands and Messages (e.g., verbal descriptions, protocols/syntax & formats, parameters & parameter definitions, state transitions, checks, error conditions, responses)

b. Data rates

c. Memory (e.g., types, usage, mapping, handling – allocation/deallocation, separation & access)

d. Communication protocols



Source: https://assist.dla.mil -- Downloaded: 2026-10-26T10:53Z
Check the source to verify that this is the current version before use.

e. Timing characteristics

f. Detailed descriptions of alarm conditions and responses

g. Detailed descriptions of check functions

3.4.3.2. If a government-approved product, either a Government off the Shelf (GOTS) or Commercial off the Shelf (COTS) product, is embedded in the design, provide a detailed description of how the security features of that approved product are utilized in the system, including specific configurations, implementations, and modes of operation used. If the embedment is being used to satisfy system security requirements, a detailed description of how the host system utilizes and preserves the integrity of the security features of the embedded product is included in this chapter. This must include a detailed description of all interfaces, and how the host handles critical information passed to and from the embedded product.

3.4.3.3. If the HAD includes the implementation of a cryptographic algorithm, rather than the embedment of a previously certified implementation of an algorithm such as in a cryptographic module, the functional description of the algorithm should include a detailed block diagram showing all logical operations, timing delays and mode of operation. The diagram ensures the Developer correctly understands the function of the algorithm. The necessary alarms, checks, and other security critical functions associated with the algorithm implementation are described in their appropriate functional block description. All cryptographic algorithms, protocols, and applications for waveforms implemented in the HAD should be provided in a list or table for the first submission of the SED. All modes of operation used for each algorithm implemented should be included with a description of the intended cryptographic application. This information should be updated as the system design matures and cryptographic features are added or removed from the design.

3.4.3.4. Where several functions have identical descriptions, a single written description is included with the first reference to that function. In subsequent references, the original description may be referenced by supplying the appropriate paragraph numbers. Care is taken to identify any name changes or minor variations to the original description to ensure the reader can follow the flow of a security critical function without misinterpretation.

3.4.4. Chapter 3. Fail Safe Design Analysis (FSDA) Modernized Process

3.4.4.1. This chapter will document the first two FSDA Steps in the Modernized Process, which is based on a reduced set of the Steps defined in the C Technical Report 02-00. The Step numbers in parenthesis refer to the Step taken from this document that still apply in the Modernized Process:

a. Identify the Required Security Services (Step 1) and Data Classification Level (New)

b. Determine which SERD Unauthorized Events are applicable and provide rational for those that are not (Step 4)



Source: https://assist.dla.mil -- Downloaded: 2026-10-26T10:53Z
Check the source to verify that this is the current version before use.

3.4.4.2. Functional/Physical Decomposition (Step 6) – This chapter also provides a functional and physical description/decomposition of the HAD being designed, giving the reader an explanation of the hierarchy of functions within the HAD and how this functional architecture satisfies the top-level requirements identified in Chapter 1. The description logically flows from the HAD's top-level functions, down through several layers of functional partitioning, to a functional design level where each function represents an individual task that is identified as occurring within or by a specific physical element of the system. The description provides the reader with an explanation of the functional and physical elements of the system (e.g., hardware, tamper approach, software, databases, and communication paths) and their relationships to each other (e.g. Client/Server, sub-element). The description associates the functions identified in this Chapter to specific elements, explaining the interdependencies among the elements in achieving functionality, and provides FSDA Functional-to-Physical System Decomposition as detailed in the C Technical Report 02-00, Fail-Safe Design & Analysis: Revised, referenced above.

3.4.4.3. This chapter deals with the last two Steps of Modernized Fail-Safe Design Analysis that address:

a. Unauthorized Events Analysis & Failure Summary (Steps 7 and 9)

b. Physical Pin-to-Pin Analysis (Step 8)

3.4.4.4. Detailed information related to the content of the Steps specified above is provided in the C Technical Report 02-00, Fail-Safe Design & Analysis: Revised, referenced above.

3.4.5. Chapter 4. Anti-Tamper Report

3.4.5.1. This chapter documents details for the physical anti-tamper features and mechanisms within a HAD as specified by the Security Evaluation Requirements Document (SERD). The anti-tamper components will be identified as active or passive, and explain the penalty or indicators that provide evidence of an attempt to breach the HAD Tamper Boundary. Each anti-tamper related requirement within the SERD must be addressed within Appendix A, and this chapter will include the narrative, to include mechanical drawings and electrical schematics, to properly explain and illustrate how each requirement is satisfied. If a particular requirement is not implemented, the associated narrative must detail why, including rationale, security policy, and any other considerations.

3.4.6. Chapter 5. Final Covert Channel Analysis Report (CCA)

3.4.6.1. This chapter includes a documented description of the CCA. A covert channel is a method of communicating data through or within a system in violation of the information flow policy using paths that are not intended to carry the data. Covert channels only exist in the context of systems that require information flow policies to be enforced. Covert channels are characterized as either storage or timing channels as defined below. The covert channel analysis must address both types of channels.

3.4.6.2. A storage channel is a covert channel that directly or indirectly writes to a storage location in order to pass information. The storage location may correspond to data-at-rest, such



Source: https://assist.dla.mil -- Downloaded: 2026-10-26T10:53Z
Check the source to verify that this is the current version before use.

as a file on disk. Example of this include using steganography to encode a message in the low order bits of an image or modulating the size of a text file. Alternatively, a storage channel may write to storage locations corresponding to data in transit (e.g., using protocol header fields which may bypass filtering or encryption) with non-fixed values to convey information through a network encryptor or a firewall.

3.4.6.3. In contrast, a timing channel is a covert channel where time is the shared resource. In timing channels, processes modulating their own access to a common resource (e.g., a microprocessor) convey information. While one process has access, the other process measures the length of time it must block before it is granted the resource. During a given time slice, the sender may hold access to signal a 1 or release access immediately to signal a 0.

3.4.6.4. The CCA Report must contain the following:

a. A description of the covert channel protection policy must be provided that mitigates violations to the information flow requirements. The policy must document how the assurance required for the system is commensurate with the sensitivity of the information protected and risks associated with the technology and operating environment.

b. The covert channel protection policy must specify the level of CCA, (i.e., informal, systematic/formal, or exhaustive), required for the target system.

- For a systematic CCA, the analysis must describe how it is structured and repeatable.
- For an exhaustive CCA the analysis must describe how it is structured, repeatable, and exercises all possible methods for determining the existence of covert channels.

c. The covert channel protection policy must specify whether covert channels are to be documented, limited (in terms of capacity), monitored, or eliminated. For a particular system, multiple mitigations may be specified, and the distinction must be based on the characteristics of an individual channel.

d. The CCA must document the analysis of each information flow policy specified in the system security policy in terms of a potential covert channel.

e. The CCA must document the analysis of both the design and implementation of the target system for potential covert channels. Low-level implementation details, including external interface definitions and source code or hardware logic specification must be used as inputs to the analysis.

f. The CCA must document the analysis of all bypass policies for potential creation of covert channels.

g. The CCA must identify each covert channel and describe a worst-case exploitation scenario for the channel.

h. The CCA must identify the characteristics of each channel, including but not limited to:



Source: https://assist.dla.mil -- Downloaded: 2026-10-26T10:53Z
Check the source to verify that this is the current version before use.

- categorization (storage or timing)
- capacity estimate (including the method used for estimation)
- direction (ingress, egress, bidirectional)
- encoding (direct or indirect)
- reliability (noisy or noiseless)

i. The CCA must describe all assumptions made during the analysis and provide evidence that the level of analysis and mitigation complies with the specified policy. An example of such an assumption would be the relative physical or logical location of the processes participating in the covert communication. For example, for an inline network encryptor, the processes may be hosts residing on the plaintext and ciphertext networks. Alternatively, a covert channel may require malicious code to be executing in the network processors themselves.

3.4.7. Appendix A. Requirements Compliance and Traceability Matrix

3.4.7.1. Appendix A of the SED contains the list of SERD requirements, and provides a high-level description of how each requirement is being met, with a pointer to the appropriate chapters and paragraph numbers supplying the supporting design details. Each applicable requirement in the SERD must be addressed separately. If the requirement applies to more than one area of the design, the design approach for each area is addressed separately. Care must be taken to identify any name changes, or minor variations to the original description to ensure the reader can follow the design implementation without misinterpretation. The security requirements are usually organized within a Requirements Compliance and Traceability Matrix with a corresponding compliance designator and statement.

3.4.7.2. There are three potential compliance designator responses for applicable SERD requirements: Fully Compliant (Met), Partially Compliant (Partially Met), and Non-Compliant (Not Met). If a stated requirement does not apply or is partially applicable to the proposed implementation, it must be stated and justified as to why. If the design is non-compliant for a security requirement, a detailed explanation must be provided in the compliance matrix. If the design is partially compliant for a security requirement the compliance statement should explain to what extent the design is compliant, as well as why the design falls short of full compliance. If agreed upon by the customer, certification manager, and evaluator, a partially or non-compliant product requirement may be designated as a “push-up” requirement that will be levied against a higher-level system that will embed the product, and bring the overall system into full compliance with that security requirement.

3.4.8. Appendix B. Comment and Response Matrix

3.4.8.1. Appendix B of the SED tracks NSA security evaluator comments along with the appropriate Developer responses and changes. These responses must answer the question or comment and reference corresponding locations in the body of the document where the content was updated in response to the comment, and marked by Change Bars. These comments and responses should include remedial actions conducted to address deficiencies and remain within the SED for each revision.



Source: https://assist.dla.mil -- Downloaded: 2026-10-26T10:53Z
Check the source to verify that this is the current version before use.

3.5. Submissions.

3.5.1. The submission of the SED chapters must support timely evaluation of the security architecture for hardware, software and test documentation to coincide with program development milestones. The SED must be submitted in three phases, planned around the Preliminary and Critical Design Review development milestone meetings. Each phase will require updates to address the comments and feedback submitted to achieve "Conditional Acceptance," which is required to enter the scheduled milestone meeting. A SED phase submission must be "Technically Acceptable" to move to next SED phase submittal and meet the criteria to exit the corresponding milestone meeting. Phase 1 is tied to the PDR milestone entrance and exit criteria. The Phase 2 submittal comes between the PDR and CDR milestones after the Phase 1 SED is deemed technically acceptable. Phase 3 is tied to the CDR milestone entrance and exit criteria. Failure to comply with the prescribed DID submission content may lead to formal rejection of that phase submission, potentially requiring additional submissions that lead to program schedule delays. The document content provided for the phase submissions must model the following.

- The Phase 1 SED must include:
  - Chapter 1 – System Requirements & Operational Environment
  - Chapter 2 – Security Architecture *
  - Chapter 3 – FSDA *
    - Identify Required Security Services and Data Classification Level
    - Identify SERD applicable Unauthorized Events (UE)/justify SERD non-applicable UEs
  - Chapter 4 – Anti-Tamper *
  - Appendix A – Requirement Compliance and Traceability Matrix *
  - Appendix B – Comment & Response Matrix *

  The Phase 1 SED content must be Conditionally Acceptable at a minimum for NSA to participate in PDR. The conditions of, and plan for, full Technical Acceptance will be agreed to during PDR. Subsequent revisions must be submitted until deemed Technically Acceptable by NSA to exit PDR and move on to Phase 2.

  * The content in these chapters is understood to be evolving as the HAD architecture matures throughout the development process, and updated to add new design details, as well as address the comments submitted for Phase 1.

- The Phase 2 SED must include:
  - Chapters 1 – System Requirements & Operational Environment (*Technically Accepted*)
  - Chapter 2 – Security Architecture **
  - Chapter 3 – FSDA **
    - Identify Required Security Services and Data Classification Level (*Technically Accepted*)
    - Identify SERD applicable Unauthorized Events (UE)/justify SERD non-applicable UEs (*Technically Accepted*)
    - Functional/ Physical Architecture & System Decomposition **



Source: https://assist.dla.mil -- Downloaded: 2026-10-26T10:53Z
Check the source to verify that this is the current version before use.

- Chapter 4 – Anti-Tamper **
- Chapter 5 – Covert Channel Analysis **
- Appendix A – Requirement Compliance and Traceability Matrix **
- Appendix B – Comment & Response Matrix **

The Phase 2 SED must be Technically Acceptable prior to submitting Phase 3 SED content.

** This Phase 2 SED content is understood to be evolving and will mature as the design matures. This content must be Conditionally Acceptable at a minimum before the Phase 3 SED content submission.

- The Phase 3 SED must include:
  - Chapters 1 – System Requirements & Operational Environment (*Technically Accepted*)
  - Chapter 2 – Security Architecture ***
  - Chapter 3 – FSDA ***
    - Identify Required Security Services and Data Classification Level (*Technically Accepted*)
    - Identify SERD applicable Unauthorized Events (UE)/justify SERD non-applicable UEs (*Technically Accepted*)
    - Functional/ Physical Architecture & System Decomposition (*Technically Accepted*)
    - Conduct Unauthorized Events Analysis & Generate Failure Summary ***
    - Perform Multi-Level Data Separation and Physical Pin-to-Pin Analysis ***
  - Chapter 4 – Anti-Tamper ***
  - Chapter 5 – Covert Channel Analysis ***
  - Appendix A – Requirement Compliance and Traceability Matrix ***
  - Appendix B – Comment & Response Matrix ***

  The Phase 3 SED submission must contain the design details for all the SED chapters, and must be Conditionally Acceptable at a minimum for NSA to participate in CDR. The conditions of, and plan for, full Technical Acceptance will be agreed to during CDR.

  *** This content submission must be complete, and requires subsequent revisions and submittals to address outstanding comments until the SED Phase 3 is deemed Technically Acceptable by NSA, to exit the CDR milestone.

3.5.2. The resubmission of a given SED phase must only contain new content to address NSA comments submitted for that particular phase. The next phase content is not authorized for submission until the current phase submission is Technically Acceptable.

3.5.3. The entire SED must be complete with all NSA comments properly addressed to be Technically Acceptable, to formally exit CDR, and to perform formal Security Verification Testing (SVT).



Source: https://assist.dla.mil -- Downloaded: 2026-10-26T10:53Z
Check the source to verify that this is the current version before use.

3.5.4. Further submission guidance is defined on DD Form 1423, Contract Data Requirements List.

END of DI-MISC-81762B



Source: https://assist.dla.mil -- Downloaded: 2026-10-26T10:53Z
Check the source to verify that this is the current version before use.